

Experiment No. 4

Aim:

Study and Implementation of at least any 5 methodologies of OWASP.

Theory:

OWASP pen testing describes the assessment of web applications to identify vulnerabilities. An OWASP pen test is designed to identify, safely exploit and help address these vulnerabilities so that any weaknesses discovered can be quickly addressed.

Pen testing helps organizations by:

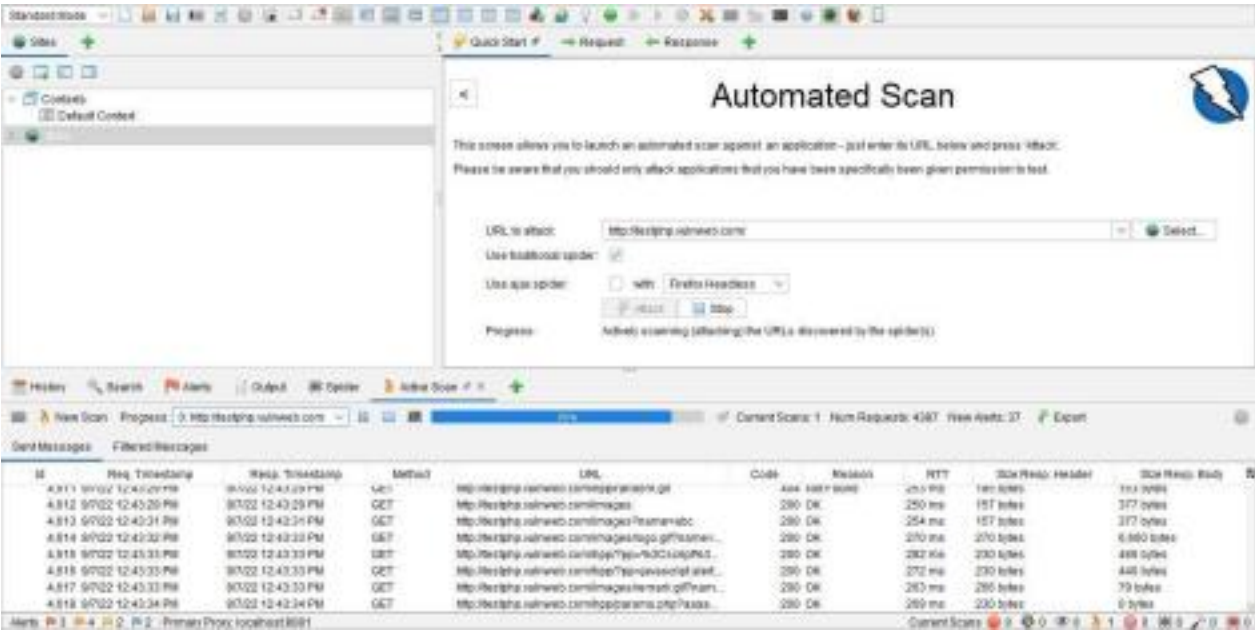
- Identifying and addressing vulnerabilities before cybercriminals have the opportunity to take advantage of them
- Reducing the risk of data breaches as well as damage and disruption to services
- Providing an independent overview of the effectiveness of security controls and better assurance for PCI DSS, ISO 27001 and GDPR compliance
- Helping to improve software development and quality assurance practices by providing insight into cyber security risks
- Supporting more informed decision-making around future security investments.

An OWASP security pentest can help to identify key vulnerabilities such as those listed in the OWASP.

1. Injection flaws
2. Broken authentication
3. Sensitive data exposure
4. XML External Entities (XXE)
5. Broken access controls
6. Security misconfiguration
7. Cross-site scripting (XSS)
8. Insecure deserialization
9. Using components with known vulnerabilities
10. Insufficient logging & monitoring

Steps Involved in OWASP Testing:

- Select the website on which you want to do test



- Test by Attacking on the Website:

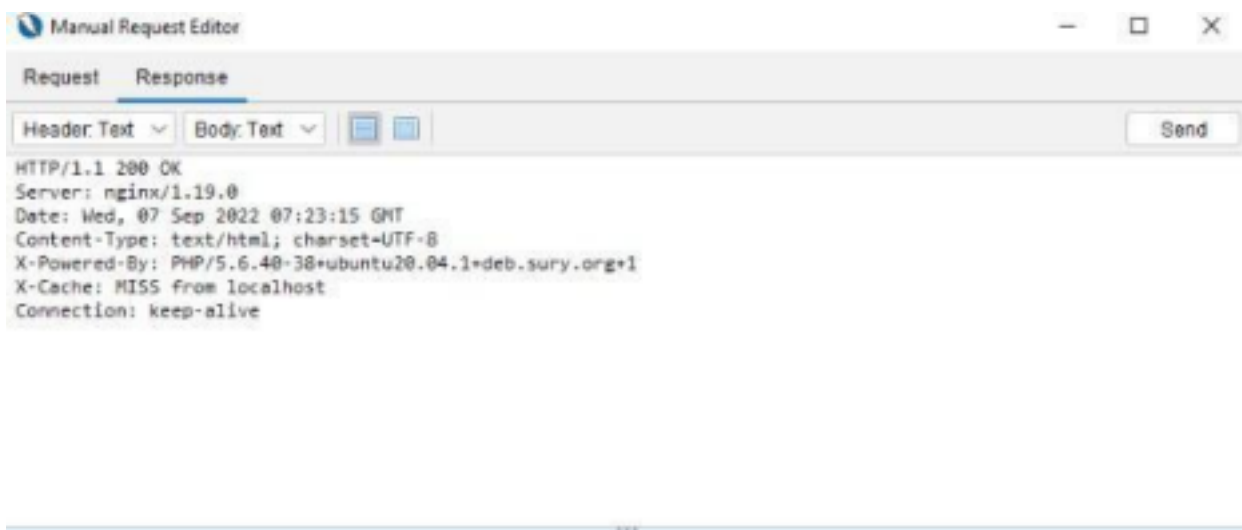
http://testphp.vulnweb.com Scan Progress						
Progress Response Chart						
Host: http://testphp.vulnweb.com						
	Strength	Progress	Elapsed	Reqs	Alerts	Status
Analysar			00:06:322	23		
Plugin						
Path Traversal	Medium		02:03:648	483	0	✓
Remote File Inclusion	Medium		01:38:654	278	0	✓
Source Code Disclosure - RWEB-RF folder	Medium		00:00:887	3	0	✓
External Redirect	Medium		01:07:089	261	0	✓
Server Side Include	Medium		00:34:481	116	0	✓
Cross Site Scripting (Reflected)	Medium		00:32:788	103	14	✓
Cross Site Scripting (Persistent) - Prime	Medium		00:13:783	29	0	✓
Cross Site Scripting (Persistent) - Spider	Medium		00:14:110	63	0	✓
Cross Site Scripting (Persistent)	Medium		00:07:821	0	0	✓
SQL Injection	Medium		02:39:831	648	7	✓
Server Side Code Injection	Medium		00:58:582	232	0	✓
Remote OS Command Injection	Medium		02:45:276	669	0	✗
Directory Browsing	Medium			0	0	✗
Buffer Overflow	Medium			0	0	✗
Format String Error	Medium			0	0	✗
CRLF Injection	Medium			0	0	✗
Parameter Tampering	Medium			0	0	✗
ELMH Information Leak	Medium			0	0	✗
Intaccess Information Leak	Medium			0	0	✗
Script Active Scan Rules	Medium			0	0	✗
Cross Site Scripting (DOM Based)	Medium			0	0	✗
SOAP Action Spoofing	Medium			0	0	✗
SOAP XML Injection	Medium			0	0	✗
Totals			12:54:761	3864	21	

http://testphp.vulnweb.com Scan Progress						
Progress Response Chart						
Host http://testphp.vulnweb.com						
	Strength	Progress	Elapsed	Reqs	Alerts	Status
Analyser			00:06.029	23		
Plugin						
Path Traversal	Medium		02:00.374	483	0	✓
Remote File Inclusion	Medium		01:30.911	270	0	✓
Source Code Disclosure - /WEB-INF folder	Medium		00:00.783	3	0	✓
External Redirect	Medium		01:04.260	261	0	✓
Server Side Include	Medium		00:32.979	116	0	✓
Cross Site Scripting (Reflected)	Medium		00:30.957	103	14	✓
Cross Site Scripting (Persistent) - Prime	Medium		00:12.611	29	0	✓
Cross Site Scripting (Persistent) - Spider	Medium		00:13.767	63	0	✓
Cross Site Scripting (Persistent)	Medium		00:06.866	0	0	✓
SQL Injection	Medium		02:34.506	642	8	✓
Server Side Code Injection	Medium		00:57.093	232	0	✓
Remote OS Command Injection	Medium		03:51.255	1015	0	✓
Directory Browsing	Medium		00:13.196	63	0	✓
Buffer Overflow	Medium		00:13.662	29	0	✓
Format String Error	Medium		00:25.918	87	0	✓
CRLF Injection	Medium		00:51.192	203	0	✓
Parameter Tampering	Medium		00:53.239	203	0	✓
ELMAH Information Leak	Medium		00:00.249	1	0	✓
htaccess Information Leak	Medium		00:06.691	17	7	✓
Script Active Scan Rules	Medium		00:00.000	0	0	✗
Cross Site Scripting (DOM Based)	Medium		00:00.457	0	0	✗
SOAP Action Spoofing	Medium		00:04.479	0	0	✓
SOAP XML Injection	Medium		00:07.063	0	0	✓
Totals			16:37.535	4147	29	

- Check the different types of Parameters of Attack Website.

OWASP ZAP - OWASP ZAP 2.11.1						
File Edit View Analyse Report Tools Injext Export Online Help						
Standard Mode						
Please be aware that you should only attack applications that you have been specifically given permission to test.						
URL to attack: http://testphp.vulnweb.com/						
History Search Alerts Output Spider Active Scan Dealpoints						
Site: testphp.vulnweb.com:80 Report						
Type	Name	Used	#Values	% Change	Flags	Values
FORM	addradi...	1	7	100		1, 2, 3, 4, 5, 6, 7
FORM	goOut...	1	1	0		go
FORM	name	1	1	0	ZAP	
FORM	pass	1	1	0	ZAP	
FORM	place	1	7	100		500, 999, 15000, 900, 1300, 10000, 490
FORM	search...	1	1	0	ZAP	
FORM	signup	1	1	0		signup
FORM	submit	1	1	0		add message
FORM	test	1	1	0		
FORM	update...	1	1	0		
FORM	url	1	1	0	ZAP	
FORM	urlmail	1	1	0	ZAP	
FORM	urlname	1	1	0	ZAP	
FORM	urlpass	1	1	0	ZAP	
FORM	urlpass2	1	1	0	ZAP	
FORM	urlname	1	1	0	ZAP	
FORM	urlname	1	1	0	ZAP	
URL	url	6	3	60		1, 2, 3
URL	url	4	4	100		1, 2, 3, 4

- Run the request and check the payload output:



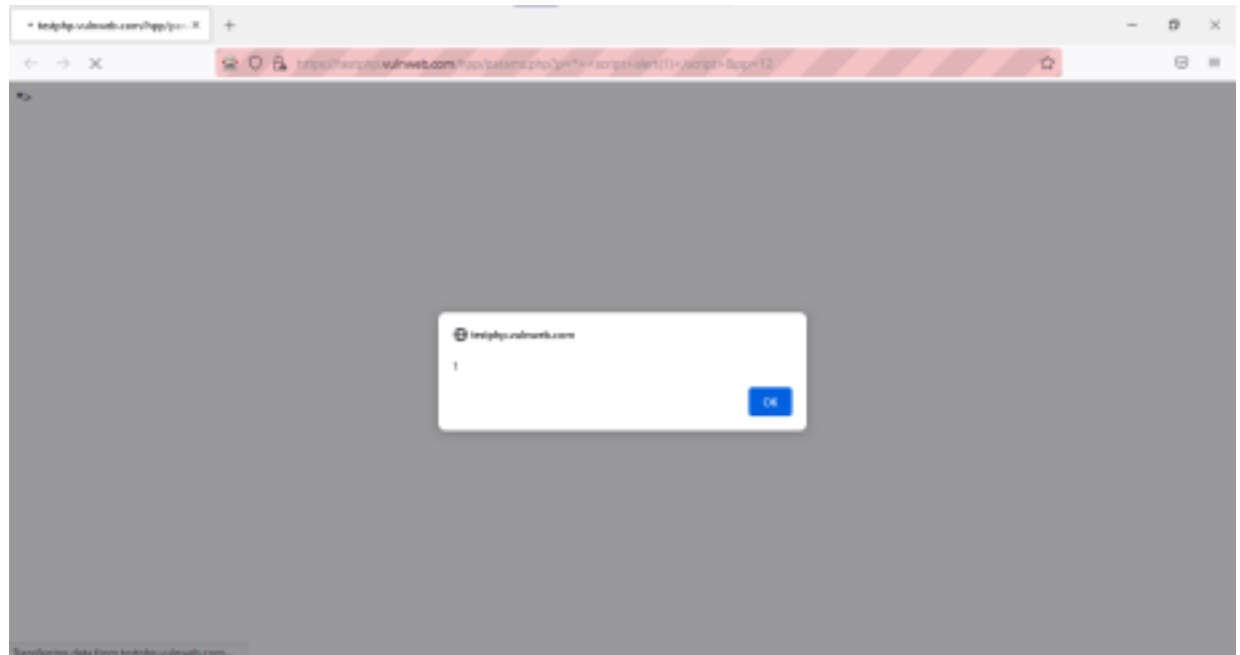
- Change the Payload in the script



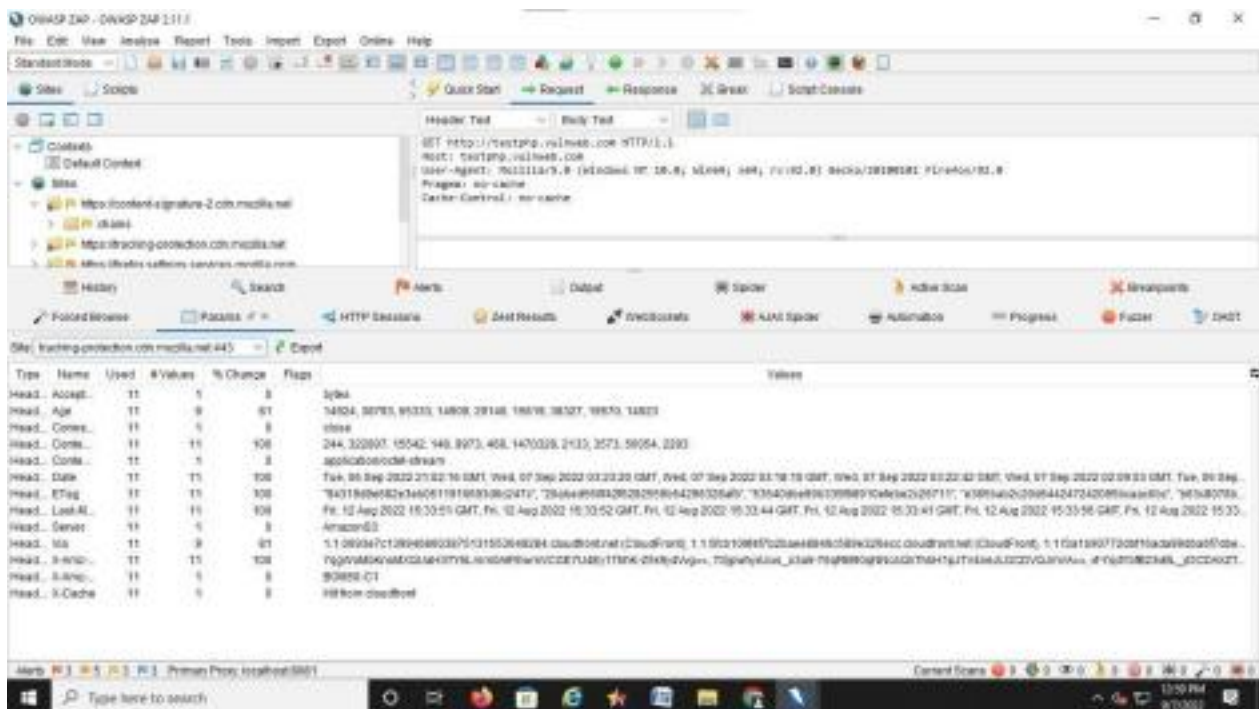
- Run the request and check the output in the tool.



- Check the output in the Website.



- Check the output of our Vulnerability Test.



Conclusion: Thus, we have studied the implementation of OWASP methodologies.